utthunga
Engineering Transformation

# SOP-CODING

[CONFIDENTIAL]
[UTTHUNGA]
[ IndiQube, South Summit, South End Rd, Vijayarangam Layout, Bengaluru, Karnataka 560004]

# Contents

1 Purpose ..... 4
2 Scope ..... 4
3 Abbreviations ..... 4
4 Terms and Definitions ..... 4
5 Responsibilities ..... 4
6 RACI ..... 5
7 SIPOC ..... 5
8 Overall Process Flow Chart ..... 6
9 Process Description ..... 7
10 Information Security requirements ..... 9
11 Metrics ..... 10
12 References ..... 10
13 Annexures ..... 11
14 Forms ..... 11

## CHANGE HISTORY

This section describes the details of changes that have resulted in the current document.

| SL. No. | Document Version No. | Change Description | Reason For change | Prepared By & Date | Reviewed By & Date | Approved By & Date |
|---|---|---|---|---|---|---|
| 01 | 0.1 | Draft | Implementation of the Integrated Management System | Megha VK 04-Jul-22 | | |
| 02 | Issue B Version 1.0 | Revised the Document to suit the requirements for implementation of the IMS | | | Sushmitha S 06-Jul-22 | Rama G 08-Jul-22 |
| 03 | Issue B Version 1.1 | Unit Testing Process added in Sec 2 | Unit Testing Process details enhanced | Parikshith K 24-May-23 | Anitha N 28-May-23 | Rama G 31-May-23 |
| 04 | Issue B Version 1.2 | Revised with SBOM Analysis and Static Code Analysis | | Anitha N 19-Jul-23 | Rakesh 25-Jul-23 | Rama G 28-Jul-23 |
| 05 | Issue B Version 1.3 | 1. Updated section 9.1.5 C<br>2. Document formatting done as per document guidelines | Added code review procedure while using centralized tool for review | Devansh S 27-Nov-24 | Anitha N 06-Nov-24 | Santosh V 10-Dec-24 |
| 06 | Issue C Version 1.0 | Review of document | New version update of IMS | Anitha N 01-Aug-2025 | Santosh V 08-Aug-25 | Sanmangala MS 14-Aug-2025 |
| 07 | Issue C Version 1.1 | Updated Github copilot usage based on PPM effectiveness | Section 9.1.2 i | Anitha N 25-Sep-2025 | Santosh V 25-Sep-2025 | Sanmangala MS 25-Sep-2025 |

# 1 Purpose

To define a procedure to ensure controlled development and maintenance of the project at Utthunga.

# 2 Scope

This applies to all the projects in Utthunga.

# 3 Abbreviations

a. PM: Project Manager

b. CRC: Code Review Checklist

c. CD: Coding

d. TST: Testing

# 4 Terms and Definitions

NIL.

# 5 Responsibilities

a. Execute full software development life cycle (SDLC)

b. Develop flowcharts, layouts and documentation to identify requirements and solutions.

c. Write well-designed, testable code.

d. Produce specifications and determine operational feasibility.

e. Integrate software components into a fully functional software system.

f. Design, develop and execute unit test plans, test designs, test cases and test strategies.

g. Design, develop and execute subsystem test plans, procedures and processes.

h. Document all test plans, test cases and strategies procedures and issues.

i. Design and implement test scripts on test tools and scripting languages.

j. Coordinate and collaborate with outside test partners.

k. Design, develop and implement program and process improvements.

l. Design and develop coding, code reviews, unit testing and release management.

m. Develop design specifications in accordance with business requirements and issues.

n. Recommend strategic improvements to optimize performances.

o. Perform analyses and interpretations of strategies and software applications.

## 6 RACI

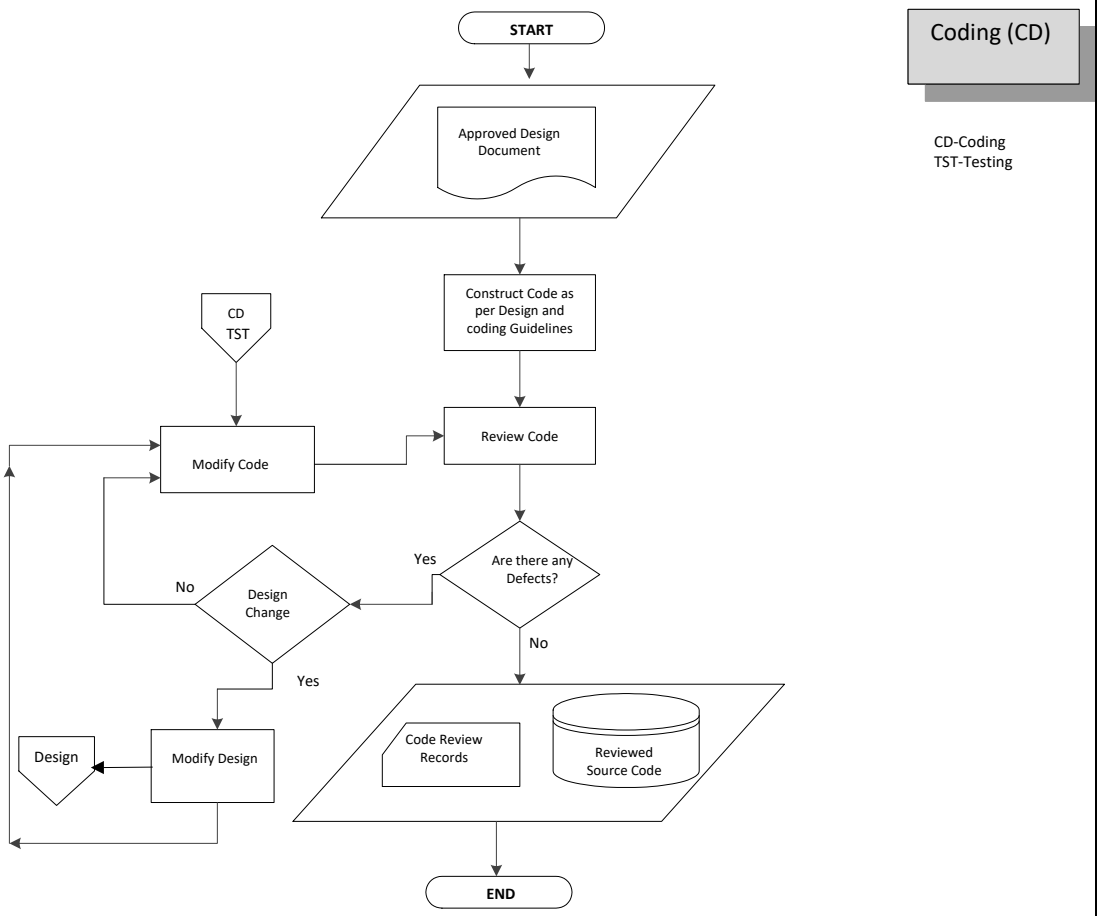
| Process | Responsible | Accountable | Consulted | Informed |
|---|---|---|---|---|
| Coding process | Developers | Project Manager | Technical Leads / Architects<br>Quality Team | Customer / Top Management |

## 7 SIPOC

| Supplier | Input | Process and Control | | Output | Customer |
|---|---|---|---|---|---|
| | | Process | Control | | |
| Customer / Internal Process / Quality | Approved Design Document | Design process | Checklist based review | Reviewed and Unit Tested Source Code | Customer / Internal Process |

# 8 Overall Process Flow Chart

## a. Coding Practices Process




-
-

# 9 Process Description

## 9.1 Coding Practices Process

### 9.1.1 General

a. Control of conforming and non-conforming source code shall be implemented as defined in the process Configuration Management and Control of Non-Conforming Product respectively.

b. The Project Manager (PM) or person designated by PM shall maintain the quality records related to code review in the project file (hardcopy) or as soft copy in the configuration area. Following documented information shall be maintained.

- Filled code review checklists.
- Review Records, wherever there is a non-conformance observed as per the checklist.

### 9.1.2 Coding

a. Coding shall be done as per the Design document.

b. Coding shall be done following the Project specific Coding Standards / Guidelines.

c. In case of Security requirements, follow Secure Coding guidelines / Standards

d. Codes shall be identified for traceability for the requirement.

e. The Developer shall write unit test cases and perform the unit testing.

f. The issues identified during the unit testing shall be resolved

g. The Developer shall record the results of the test in the Unit Test Report.

h. Unit tested code shall be used to generate the build and shared with the testing team for system testing / integration testing.

i. Auto generation of code and unit test case creation using licensed Github co-pilot can be explored subject tp permission from customer and approval from delivery manager.

### 9.1.3 Static Code Analysis

a. All source code must be scanned and analyzed using a static analysis tool to generate potential code quality issues or vulnerabilities in the source code.

b. The results of the Static Code Analysis will have to be reviewed by the Project Manager or person designated by Project Manager as well as a Security Engineer.

c. All the findings of the Static Code Analysis shall be documented and maintained in a report and tracked to closure.

d. Such static code analysis scans should be run at least once every sprint.

e. In case, there is a non-conformity identified during Static Code Analysis, the Project Manager or person designated by Project Manager shall decide the following:

- Reject the code, rejected or Scrapped Non-conforming code shall be stored in a location (for e.g. Version Control Repository) and identified as non-conforming products to prevent unintended usage
- Accept the code, i.e. Rework to meet the specified requirement
- Accept with modification
- Project member shall take corrective action based on the review record
- For the final release of the application, all issues detected in such Static Code Analysis scans should be mitigated.

### 9.1.4 SBOM Analysis

a. All source code should be subject to a Software Composition Analysis scan to generate a Software Bill of Materials or SBOM.

b. A risk review will have to be conducted for the list of components in the SBOM by including the Security Engineer as well as the Project Manager or person designated by Project Manager.

c. Once the risk review for the SBOM has been completed, a decision shall be made on which potential vulnerabilities or risks shall be fixed and which will not, which shall all be tracked to closure.

d. In case, there is a non-conformity identified during the SBOM Analysis, the Project Manager or person designated by Project Manager shall decide the following:

- Reject the code, rejected or Scrapped Non-conforming code shall be stored in a location (for e.g. Version Control Repository) and identified as non-conforming products to prevent unintended usage
- Accept the code, i.e. Rework to meet the specified requirement
- Accept with modification
- Project member shall take corrective action based on the review record
- For the final release of the application, all the issues identified to be fixed during the risk review for the SBOM should be mitigated.

### 9.1.5 Code Reviews

a. Code Review shall be performed to ensure that the source code is:

- Meeting requirements as mentioned in Design
- Complying with the Coding standards / guidelines

b. The Project Manager or person designated by Project Manager shall ensure the code reviews are done, using the Code Review Checklist (CRC).

c. Review of the code shall be done in one of the ways as described below:

- Review conducted and findings shall be recorded in the Review Form and tracked to closure.
- Review conducted and findings shall be provided in the centralized tool and tracked to closure. (Refer sections 12.g and 12.h for detailed process).

d. In case, there is a non-conformity identified during Code Review, the Project Manager or person designated by Project Manager shall decide the following:

- Reject the code, rejected or Scrapped Non-conforming code shall be stored in a location (for e.g. Version Control Repository) and identified as non-conforming products to prevent unintended usage
- Accept the code, i.e. Rework to meet the specified requirement
- Accept with modification
- Project members shall take corrective action based on the review record.

### 9.1.6 Rework

a. All Test defects shall be fixed.

b. Debug shall happen and code shall be modified for bug fixing.

c. Uniquely identified bug tracking number provided by the bug tracker shall be tracked at the code level by giving appropriate code comments for easy identification and Traceability of Testing defects and Customer identified bugs.

## 10 Information Security requirements

a. The information security related requirements shall be included in the requirements for new information systems or enhancements to existing information systems.

b. Information involved in application services passing over public networks shall be protected from fraudulent activity, contract dispute and unauthorized disclosure and modification.

c. Information involved in application service transactions shall be protected to prevent incomplete transmission, misrouting, unauthorized message alteration, unauthorized disclosure, unauthorized message duplication or replay.

d. Rules for the development of software and systems shall be established and applied to developments within the organization.

e. Changes to systems within the development lifecycle shall be controlled using formal change control procedures.

f. When operating platforms are changed, business critical applications shall be reviewed and tested to ensure there is no adverse impact on organizational operations or security.

g. Modifications to software packages shall be discouraged, limited to necessary changes and all changes shall be strictly controlled.

h. Principles for engineering secure systems shall be established, documented, maintained, and applied to any information system implementation efforts.

i. Organizations shall establish and appropriately protect secure development environments for system development and integration efforts that cover the entire system development lifecycle.

j. The organization shall supervise and monitor the activity of outsourced system development.

k. Testing of security functionality shall be carried out during development.

l. Acceptance testing programs and related criteria shall be established for new information systems, upgrades, and new versions.

m. Test data shall be selected carefully, protected, and controlled.

n. Confidentiality of data is maintained.

# 11 Metrics

a. Code Review Efficiency: Defects detected in Code review/ Time taken for code review

b. Code Review Effectiveness: Code Review Defects / Code Review Size (Kloc)

c. Code Development Productivity: No of lines of written source code (KLOC) / Effort spent

# 12 References

a. ISO 9001 Clauses 8.5, 8.6

b. ISO 27001 Clauses 8.1, Controls A.6, A.7, A.9, A.10, A.12, A.14

c. ISMS Control Policies

d. Language / Platform based coding guidelines as published by language / platform framework provider.

e. Patch Management Guidelines UT/SD/CDP/GDL/01

f. Secure Development Lifecycle Guidelines UT/SD/CDP/GDL/02

g. GitHub Code Review Process

h. GitLab Code Review Process

# 13 Annexures

a. NIL

# 14 Forms

a. Application Security Checklist UT/SD/CDP/TMP/01

b. General Code Review Checklist UT/SD/CDP/TMP/02

c. CPP Code Review Checklist UT/SD/CDP/TMP/03

d. DotNet Peer Code Review Checklist UT/SD/CDP/TMP/04

e. DotNet RC Code Review Checklist UT/SD/CDP/TMP/05

f. IOS Peer Code Review Checklist UT/SD/CDP/TMP/06

g. IOS RC Code Review Checklist UT/SD/CDP/TMP/07

h. JAVA Code Review Checklist UT/SD/CDP/TMP/08